Instituto Tecnológico de Costa Rica
Escuela de Ingeniería en Computadores
CE-1115 Seguridad de la Información

Proyecto · Parte 1 · Diseño del control de acceso

Informe de políticas de seguridad

Qué protegemos y bajo qué reglas

Entregable 1 de 5

Preparado para

Gerencia de Verdeazul Carbono S.A.
Certificación de captura de carbono · Pérez Zeledón, Costa Rica

Grupo 6

Integrante	Carné
Randall Bryan Bolaños López	2019043784
Javier Tenorio Cervantes	2020065308
Julio Varela Venegas	2019008041
Axel Flores Lara	2021453573

Prof. MSc. Andrés Vargas Rivera
Semestre II, 2026

Fecha de entrega: 15 de octubre de 2026

Índice

1. Propósito y alcance **1**

2. Qué protegemos: activos y clasificación **1**

2.1. Niveles de clasificación 1

2.2. Inventario de activos de información 1

3. La tríada aplicada a Verdeazul **2**

4. Modelo de amenazas **3**

5. Marco regulatorio y reglas operativas **5**

6. Política de cuentas y accesos **6**

6.1. Alta, cambio de puesto y baja 6

6.2. Asignaciones, vínculos y revisión periódica 7

6.3. Bitácora: qué se registra y por cuánto tiempo 8

6.4. Transición: las hojas de cálculo actuales 9

7. Política de contraseñas y autenticación **9**

8. Política de períodos, correcciones y certificados **11**

9. Cumplimiento **12**

Anexo A. Minuta de la consulta al cliente **13**

Anexo B. Supuestos declarados **20**

Referencias **21**

1 Propósito y alcance

Verdeazul lleva hoy su operación en hojas de cálculo compartidas y ya tuvo dos sustos: una medición que alguien modificó después de aprobada sin que se sepa quién, y un certificado que se emitió dos veces sobre la misma hectárea. Este informe fija las reglas que la nueva plataforma debe hacer cumplir para que eso no vuelva a ocurrir, y para que la empresa pueda explicarle a un auditor por qué su sistema está diseñado así.

No es un manual técnico. Es el marco del que salen las decisiones de control de acceso (Entregables 2 y 3) y de arquitectura (Entregable 4): cada regla de esos documentos responde a un activo, a una amenaza o a una obligación legal de los que se describen aquí.

A quién obliga. A todo el personal de Verdeazul; a los auditores externos mientras dure su auditoría, trabajen en sitio o a distancia; a los dueños de finca y a sus representantes; al personal que opere la plataforma y al proveedor que la hospede.

Qué cubre. La plataforma de certificación y toda la información que maneja, en cualquier soporte: el sistema, sus respaldos, los reportes que se exporten y, durante la transición, las hojas de cálculo actuales.

Cómo se lee. Las reglas numeradas (POL-) son obligatorias. Cada una está escrita de modo que se pueda comprobar si se cumple; una regla que no se puede comprobar está mal escrita. Las marcas como [minuta P-07] señalan reglas que salen de una respuesta del cliente; la minuta de esa consulta es el Anexo A. Las marcas como [supuesto P-17] señalan supuestos que el equipo fijó porque el cliente no dio el dato; están en el Anexo B.

2 Qué protegemos: activos y clasificación

2.1 Niveles de clasificación

Nivel	Qué significa en Verdeazul	Quién puede verlo
Público	Información que la empresa publica: su metodología y sus datos institucionales.	Cualquiera.
Interno	Información de trabajo que no identifica fincas ni personas: procedimientos y calendario de períodos.	Todo el personal.
Confidencial	Información cuya divulgación perjudica a un dueño frente a sus competidores, a una persona o a la empresa.	Solo quien la necesita para su función, finca por finca.
Restringido	Información que, si se altera o se filtra, compromete la credibilidad de todos los certificados.	Un grupo mínimo, nombrado, y siempre con registro.

2.2 Inventario de activos de información

La tabla valora cada activo en los tres pilares, con la escala de FIPS 199: el impacto de perder confidencialidad (C), integridad (I) o disponibilidad (D) es alto (**A**), medio (M) o bajo (B). El *responsable* es quien decide sobre el dato, no quien administra el sistema donde vive.

Id.	Activo	Qué es y por qué vale	Clasificación	C	I	D
A-01	Mediciones de campo	Biomasa por parcela y período. De ellas salen las toneladas: un dato inflado es fraude.	Confidencial	M	**A**	M
A-02	Certificados de carbono	Lo que el dueño vende. Cada uno respalda una tonelada real.	Confidencial	M	**A**	M
A-03	Catálogo de fincas y parcelas	Qué fincas hay, dónde, de quién y con qué área. Es la cartera de clientes y la base contra la doble emisión.	Confidencial	**A**	**A**	M
A-04	Datos personales de los dueños	Identificación y contacto de los titulares, personas físicas o sociedades, y de sus representantes. Protegidos por la Ley 8968. [supuesto P-17]	Confidencial	**A**	M	B
A-05	Dictámenes y enmiendas	Quién aprobó, quién devolvió, qué se corrigió y por qué.	Confidencial	M	**A**	M
A-06	Períodos y asignaciones	Qué período está abierto y qué técnico mide cada finca, de forma ordinaria o temporal. Deciden quién puede cambiar o ver qué.	Confidencial	M	**A**	M
A-07	Bitácora de auditoría	El rastro de quién hizo y quién consultó. Es la prueba ante el auditor.	Restringido	**A**	**A**	M
A-08	Cuentas, roles y credenciales	Quién es quién en el sistema, qué puede hacer y qué vínculos declaró con dueños de finca.	Restringido	**A**	**A**	M
A-09	Llaves y secretos del sistema	Incluye la llave con que se sellan los certificados. Quien la tenga puede fabricar certificados creíbles.	Restringido	**A**	**A**	M
A-10	Reglas y parámetros de cálculo	Ecuaciones y factores que convierten una medición en toneladas. Un factor alterado infla todos los certificados a la vez.	Interno	B	**A**	B
A-11	Respaldos	Copia de todo lo anterior. Es lo que queda si lo demás falla.	Restringido	**A**	**A**	**A**

Responsables. La Gerencia de Certificación responde por A-01 a A-07 y A-10; decide su clasificación, quién accede y por cuánto tiempo. Dentro de A-06, las asignaciones de fincas las decide el supervisor de campo. [minuta P-05] El administrador de catálogo y cuentas y el operador de plataforma son custodios: aplican los controles que la Gerencia define sobre A-08, A-09 y A-11, pero no deciden sobre el dato.

La política cuida además dos activos que no son información: las **personas** que saben medir y verificar, y el **proceso** de certificación mismo.

3 La tríada aplicada a Verdeazul

> **La integridad pesa más.** Después va la confidencialidad y, en tercer lugar, la disponibilidad. Cuando dos pilares choquen, gana la integridad.

Pilar	Qué significa en esta empresa	Cómo se pierde aquí
1. Integridad	Que cada certificado corresponda a una medición real, hecha por una persona, aprobada por otra, y que nada de eso haya cambiado después sin dejar rastro.	Los dos sustos de la carta son fallas de integridad: la medición modificada después de aprobada y el certificado emitido dos veces.
2. Confidencialidad	Que cada dueño vea solo lo suyo, que los datos personales no salgan de quien los necesita, y que la cartera de fincas no termine en la competencia.	El técnico que consultó cientos de fincas ajenas un fin de semana. No hace falta que un extraño entre: basta con que alguien autorizado para ciertos datos acceda a otros.
3. Disponibilidad	Dos cosas distintas: que el sistema responda durante las semanas en que un período está abierto, y que el dato siga existiendo y se pueda leer dentro de diez años.	Un ataque de *ransomware* como los de 2022 y 2024 en el país, o un respaldo que nunca se probó.

Por qué la integridad va primero. Un certificado vale porque alguien confía en el dato que lo respalda. Si se filtra información, el daño es serio pero acotado. Si un dato resulta falso, el auditor deja de confiar en ese certificado y en todos los demás. Y un dato alterado es más peligroso que uno robado, porque la empresa sigue tomando decisiones sobre él sin saber que es falso.

Por qué la disponibilidad va al final, y con un matiz. La operación es por períodos: un día sin sistema atrasa el trabajo, pero no destruye valor. Lo que no se puede perder es el histórico. Por eso la política exige más sobre la durabilidad (respaldos probados, regla POL-BT-07) que sobre el tiempo de respuesta. [supuesto P-24] La conexión inestable de las fincas va en la misma dirección: el técnico puede registrar más tarde, pero el dato no puede cambiar sin rastro. **[minuta P-22]**

Qué significa «gana la integridad». Si el sistema no puede escribir en la bitácora, no ejecuta la operación, aunque eso detenga el trabajo (POL-BT-06). Si no puede comprobar un permiso, lo niega.

4 Modelo de amenazas

Cada amenaza se describe con el vocabulario del curso: quién es el agente, qué lo mueve, qué activo alcanzaría y qué debilidad actual se lo permite. El riesgo combina probabilidad e impacto. **Probabilidad alta** significa que ya ocurrió en Verdeazul o que es la vía habitual de ataque en el país. **Impacto alto** significa que pone en duda certificados emitidos o detiene la operación.

Id.	Quién y con qué motivo	Qué podría lograr	Qué lo permite hoy	Riesgo	Respuesta
Amenazas internas					
AM-01	Técnico que infla una medición, por un pago del dueño o por presión de metas.	Certificados sin respaldo real (A-01, A-02). Integridad.	Nadie independiente tiene que revisar el dato antes de emitir.	**Alto**	Verificación por otra persona; validación de rangos.
AM-02	La misma persona mide y aprueba; o un técnico y un verificador de acuerdo.	Fraude completo sin testigo (A-02). Integridad.	La hoja de cálculo no distingue quién hace cada paso.	**Alto**	Separación por etapas, comprobada por medición.

Id.	Quién y con qué motivo	Qué podría lograr	Qué lo permite hoy	Riesgo	Respuesta
AM-03	Cualquier empleado que edita una medición ya aprobada, por error o para tapar algo.	Dato distinto del que se aprobó, sin rastro (A-01, A-05). Es el primer susto.	Las celdas se sobrescriben y no queda autor.	**Alto**	Versiones inmutables; cierre; enmienda.
AM-04	Empleado con credenciales válidas que quiere llevarse la cartera a la competencia.	Copia del catálogo y de datos de dueños (A-03, A-04). Confidencialidad. Es el técnico del fin de semana.	Todos ven todo y nadie mira cuánto se consulta.	**Alto**	Alcance por asignación; controles de historial graduados.
AM-05	Administrador que se otorga permisos o crea cuentas y fincas ficticias; operador que altera la base o borra el rastro.	Cualquier fraude anterior, sin dejar evidencia (A-07, A-08).	Una sola persona administra catálogo y cuentas.	Medio	Segunda firma; bitácora que no se puede reescribir.
AM-06	Empleado que, sin mala intención, emite dos veces sobre la misma hectárea.	Dos certificados por una sola tonelada (A-02, A-03). Es el segundo susto.	Nada impide repetir una parcela o traslapar dos.	**Alto**	Emisión única; parcelas sin traslape.
AM-11	Empleado con un vínculo familiar o comercial con un dueño, que usa su puesto para favorecer esa finca.	Medir de más, aprobar sin rigor, asignar a un técnico afín o autorizar una corrección al alza (A-01, A-02, A-06). Integridad.	No existe un registro de vínculos entre empleados y propietarios. **[minuta P-15]**	Medio	Declaración de vínculos y abstención.
Amenazas externas					
AM-07	Dueño de finca que quiere ver los datos de un competidor.	Mediciones y certificados ajenos (A-01, A-02). Confidencialidad.	Bastaría cambiar un identificador si el sistema no comprueba de quién es cada dato.	Medio	Regla «solo lo suyo» en cada consulta.
AM-08	Delincuente que roba una contraseña con un correo falso, o la toma de un teléfono perdido o de un equipo infectado.	Actuar como un técnico, un verificador o un dueño (A-08).	Contraseñas solas, reutilizadas; equipos de campo que la empresa no administra. **[minuta P-22]**	**Alto**	Segundo factor; reautenticación.
AM-09	Grupo de *ransomware* que busca un rescate.	Sistema detenido en pleno período o histórico destruido (A-11). Disponibilidad.	Respaldos sin probar o en el mismo sitio.	**Alto**	Respaldos 3-2-1 probados.
AM-10	Falsificador de certificados; o quien tome la cuenta de un auditor, que lo ve todo.	Certificados falsos creíbles; copia de todo el sistema (A-02, A-09).	No hay cómo comprobar si un certificado es auténtico ni si sigue vigente. **[minuta P-04]**	Medio	Sello y comprobación en línea; cuenta de auditor con ventana.

Lo que el modelo deja claro. Siete de las once amenazas son internas, y tres de ellas ya ocurrieron. El atacante más probable de Verdeazul no rompe nada para entrar: ya tiene una cuenta. Por eso el

diseño no se concentra en el perímetro, sino en lo que cada persona autorizada puede hacer, cuánto y sobre qué.

5 Marco regulatorio y reglas operativas

Estas son las obligaciones que aplican al giro de Verdeazul. La columna de la derecha traduce cada una a una regla que la empresa puede cumplir y comprobar. El análisis debe validarse con asesoría legal.

Norma	Qué exige	Regla operativa para Verdeazul
Ley 8968, Protección de la Persona frente al Tratamiento de sus Datos Personales, y su reglamento		
Art. 2, ámbito	Excluye las bases de uso exclusivamente interno.	No aplica la exclusión: los datos de los dueños se comparten con auditores externos. La ley obliga a Verdeazul.
Art. 5, consentimiento informado	Informar al titular para qué se usan sus datos, quién los verá y cómo ejercer sus derechos.	Ningún dueño se da de alta sin firmar un consentimiento que nombre a los verificadores y a los auditores, incluidos los del extranjero, y que diga dónde se hospedan los datos (POL-CA-08).
Art. 6, calidad de la información	Datos actuales, veraces y exactos; no conservarlos más de diez años si pueden afectar al titular, salvo que se desasocien.	Al cumplirse el plazo de trazabilidad, los datos personales se desasocian del registro de certificación (POL-BT-04).
Art. 7, derechos del titular	Acceso, rectificación y supresión, resueltos en cinco días hábiles.	El administrador atiende cada solicitud en ese plazo y lo deja registrado. La supresión se difiere mientras el dato respalde un certificado dentro del plazo de trazabilidad.
Art. 10, seguridad	Medidas técnicas y de organización contra la alteración, la pérdida y el acceso no autorizado.	Es el fundamento legal de todo el control de acceso de este proyecto.
Art. 11, confidencialidad	Secreto de quienes tratan los datos, aun después de terminada la relación.	Acuerdo de confidencialidad firmado por el personal, los auditores y el operador, con vigencia posterior a la salida (POL-CA-02). [supuesto P-14]
Arts. 14 y 31 f), transferencia	Transferir datos exige autorización expresa del titular; enviarlos a otro país sin ella es falta gravísima.	Los auditores consultan dentro de la plataforma, en sitio o a distancia. La evidencia que exportan identifica al titular por un código y no lleva datos personales (POL-CA-07). **[minuta P-18]**
Reglamento, arts. 38 y 39	Informar al titular y a la Prodhab de una vulneración en cinco días hábiles.	Procedimiento de incidentes con ese plazo: naturaleza del incidente, datos comprometidos y acciones tomadas.
Otras normas nacionales		
Ley 7975, Información No Divulgada, art. 2	Un secreto comercial solo se protege si su titular tomó medidas razonables para mantenerlo secreto.	Para poder reclamar si la cartera de fincas llega a la competencia, deben existir y poder demostrarse el acceso por necesidad, el registro de consultas y la confidencialidad firmada.

Norma	Qué exige	Regla operativa para Verdeazul
Código Penal, arts. 196 bis, 217 bis, 229 bis y 231	Tipifican la violación de datos personales, la estafa informática, el daño informático y el espionaje informático.	La política de uso aceptable lo advierte. La bitácora se conserva de modo que sirva como evidencia en una denuncia.
Código de Trabajo, art. 71 g)	Obliga al trabajador a guardar los secretos comerciales que conoce por su trabajo.	Base de las sanciones laborales de la sección 9.
Ley 8454, Certificados, Firmas Digitales y Documentos Electrónicos	Da al documento electrónico el mismo valor que al físico y regula la firma digital certificada.	Los certificados y las aprobaciones electrónicas tienen valor legal. La firma digital certificada de cada verificador se valoró y no se exige: el certificado lleva el sello electrónico de la empresa y su estado se comprueba en línea (POL-CE-04). **[minuta P-04]**
Normas de referencia: el cliente no audita bajo una norma determinada [minuta P-18]		
ISO 14064-3:2019, ISO 14065:2020, ISO/IEC 17029:2019 e ISO/IEC 27001:2022	Imparcialidad: quien revisa no participó en lo que revisa. Segregación de funciones, control de acceso y registro de eventos.	Se toman como buena práctica, no como obligación. La obligación firme es la del cliente: poder reconstruir la trazabilidad de todo certificado de los últimos diez años.

6 Política de cuentas y accesos

Objetivo. Que cada persona tenga exactamente el acceso que su función necesita, durante el tiempo que la ejerce, y que todo cambio de acceso deje rastro. **Responsable.** La Gerencia de Certificación decide; el administrador de catálogo y cuentas ejecuta; el supervisor de campo asigna las fincas.

6.1 Alta, cambio de puesto y baja

Regla	Qué establece	Cómo se comprueba
POL-CA-01	**Una persona, una cuenta.** Toda cuenta pertenece a una persona identificada. No hay cuentas compartidas ni genéricas.	Cuentas sin titular o con identificación repetida: cero.
POL-CA-02	**Alta con tres personas.** La jefatura solicita la cuenta e indica el rol, el administrador la crea y la Gerencia aprueba el rol. Antes de recibirla, la persona firma la política de uso aceptable y el acuerdo de confidencialidad, y declara sus vínculos con dueños de finca (POL-CA-14). [supuesto P-14, P-20]	Cada cuenta activa tiene solicitud, creación y aprobación de personas distintas, los dos documentos firmados y la declaración.
POL-CA-03	**Un rol, el de la función.** Cada persona tiene un solo rol, y no se copian los permisos de otra. La única excepción es el verificador que, en una situación excepcional, debe medir: recibe una habilitación temporal de técnico, con fecha de fin, que aprueba la Gerencia. No usa los dos roles en la misma sesión ni aprueba nunca lo que midió. **[minuta P-01]**	Cuentas con dos roles sin una habilitación vigente: cero.
POL-CA-04	**Cambio de puesto.** Primero se retira el rol anterior, se cierran las sesiones y se terminan las asignaciones; después se asigna el rol nuevo. El historial de lo que la persona registró se conserva.	Ningún cambio de rol sin retiro previo en la bitácora.

Regla	Qué establece	Cómo se comprueba
POL-CA-05	**Baja el mismo día.** La cuenta se desactiva y sus sesiones se cierran el día de la salida. Las cuentas no se borran. Cuando alguien presenta su preaviso, la Gerencia recibe un reporte de sus consultas de los últimos 90 días y revisa sus asignaciones.	Fecha de desactivación menor o igual que la fecha de salida en todas las bajas.
POL-CA-06	**Cuentas sin uso.** Una cuenta sin actividad durante 45 días se suspende sola. La reactiva la Gerencia, normalmente en la revisión previa a cada período (POL-CA-11).	Cuentas activas sin uso en 45 días: cero.
POL-CA-07	**Auditores externos.** Cuentas personales, de solo lectura, con fecha de inicio y de fin, para trabajar en sitio o a distancia. Vencen solas; prorrogarlas es una autorización nueva de la Gerencia. Pueden exportar evidencia: paquetes que genera el sistema, sellados, registrados y sin datos personales. [minuta P-18]	Cuentas de auditor activas fuera de una ventana: cero. Exportaciones sin registro: cero.
POL-CA-08	**Dueños de finca.** El titular puede ser una persona física o una sociedad, y tener varias fincas. La cuenta siempre es de una persona: el titular o un representante con autorización escrita o personería vigente. La habilita el administrador después de verificar la relación con cada finca y de archivar el consentimiento informado. El alta de un representante se notifica al titular. [minuta P-15]	Cada cuenta de dueño tiene archivados la verificación de su relación y el consentimiento.
POL-CA-09	**Operador de plataforma.** Es personal que la empresa designa. No tiene cuenta en la aplicación. Su acceso al servidor es personal, con segundo factor y registrado, y trabaja con guías escritas. El acceso directo a la base de datos es una emergencia que autoriza la Gerencia. El proveedor de hospedaje firma confidencialidad y no recibe credenciales de la aplicación. [minuta P-23]	La Gerencia y el auditor revisan el registro de accesos de emergencia.
POL-CA-10	**Nadie se administra a sí mismo.** Nadie aprueba su propio rol, modifica su propia cuenta ni atiende una alerta sobre sí mismo.	Aprobaciones en que quien solicita y quien aprueba coinciden: cero.

6.2 Asignaciones, vínculos y revisión periódica

Regla	Qué establece	Cómo se comprueba
POL-CA-11	**Revisión antes de cada período y al menos cada tres meses.** La Gerencia revisa y firma la lista de cuentas, roles, asignaciones y declaraciones de vínculos. Lo que no confirma queda suspendido.	Un acta de revisión firmada por cada período abierto.
POL-CA-12	**Revisión de señales.** El supervisor atiende las alertas de sus técnicos en dos días hábiles; la Gerencia, las demás y las que él no resuelva, en cinco. La Gerencia recibe un resumen semanal de consultas fuera de patrón, asignaciones temporales y restricciones levantadas. [minuta P-10]	Alertas abiertas por más de cinco días hábiles: cero.

Regla	Qué establece	Cómo se comprueba
POL-CA-13	**Las fincas se asignan, no se heredan.** El supervisor de campo asigna las fincas de cada técnico en cada período. Para apoyar a un compañero, sustituir a un ausente o atender una visita extraordinaria crea una asignación temporal, con motivo y fecha de fin, que vence sola. Nadie tiene acceso permanente a todas las fincas, y nadie se asigna a sí mismo. [minuta P-05, P-11]	Asignaciones temporales sin motivo o sin fecha de fin: cero.
POL-CA-14	**Declaración de vínculos y abstención.** Todo el personal declara, al ingresar y antes de cada período, las fincas con cuyo titular tiene un vínculo familiar o comercial, o que no tiene ninguno. Quien declara un vínculo no mide, no aprueba, no asigna ni autoriza nada sobre esa finca. Omitirlo es falta grave. [minuta P-15]	Personal sin declaración vigente: cero. Decisiones de alguien con vínculo declarado: cero.

6.3 Bitácora: qué se registra y por cuánto tiempo

Regla	Qué establece	Cómo se comprueba
POL-BT-01	**Qué se registra.** (a) Inicios de sesión, fallos y cambios de credenciales. (b) Toda creación, modificación, envío, aprobación, devolución, enmienda, emisión, revocación y exportación. (c) Toda consulta de fincas, mediciones, certificados y datos personales. (d) Altas, bajas, roles, asignaciones, apertura y cierre de períodos. (e) Toda petición denegada y toda alerta.	Por cada tipo de evento hay una prueba que lo provoca y lo encuentra en la bitácora.
POL-BT-02	**Qué dice cada registro.** Quién (cuenta y rol), qué hizo y sobre qué objeto, cuándo (hora del servidor), desde dónde y con qué resultado. En los cambios, además, el valor anterior y el nuevo. Cada medición guarda dos fechas: la de medición, que declara el técnico, y la de registro, que pone el servidor. [minuta P-22]	Registros con algún campo vacío: cero.
POL-BT-03	**Solo se agrega.** Nadie modifica ni borra la bitácora: ni la Gerencia, ni el administrador, ni el operador.	Verificación diaria de la cadena de la bitácora (Entregable 4).
POL-BT-04	**Conservación.** Cambios, aprobaciones, emisiones, enmiendas y actos de administración: diez años desde la emisión del certificado al que se refieren, que es la trazabilidad que el cliente debe poder reconstruir. [minuta P-18] Consultas y autenticación: dos años. [supuesto P-19] Vencido el plazo, los registros se desasocian de la persona.	Existe el registro completo de un certificado elegido al azar de cada año.
POL-BT-05	**Quién la lee.** La Gerencia y el auditor externo. Cada lectura de la bitácora queda registrada.	Lecturas de bitácora por otros roles: cero.
POL-BT-06	**Sin registro no hay acción.** Si el sistema no puede escribir el registro, no ejecuta la operación.	Prueba con la bitácora deshabilitada: la operación se rechaza.
POL-BT-07	**Respaldo.** Tres copias, en dos medios distintos, una fuera del sitio y cifrada. La restauración se prueba cada seis meses.	Acta de la última prueba de restauración, con menos de seis meses.

6.4 Transición: las hojas de cálculo actuales

Los certificados de los últimos diez años viven hoy en hojas de cálculo que cualquiera con acceso pudo editar. El cliente necesita reconstruir la trazabilidad de esos diez años. [minuta P-18] Hacia adelante, el sistema la da completa. Hacia atrás no puede crear la que nunca existió, pero sí conservar la mejor evidencia disponible e impedir que siga cambiando. [supuesto P-26]

Regla	Qué establece	Cómo se comprueba
POL-TR-01	**Congelar.** El día de la puesta en marcha las hojas quedan en solo lectura. Dos personas calculan y firman su huella digital, y se archivan por diez años.	La huella del archivo coincide con la del acta.
POL-TR-02	**Migrar una sola vez y entre dos.** El administrador carga el histórico y un verificador lo confirma por muestreo. Cada registro migrado lleva la marca «histórico, origen hoja de cálculo»: de ellos el sistema no garantiza quién los cambió antes.	Todo registro anterior a la puesta en marcha lleva la marca.
POL-TR-03	**Sin hojas paralelas.** Desde ese día no se lleva información de certificación fuera de la plataforma. La única excepción es la hoja de campo del técnico que mide sin conexión: se registra dentro de los cinco días hábiles siguientes a la visita y se archiva como respaldo. [minuta P-22]	Revisión en la capacitación anual y en la auditoría.

7 Política de contraseñas y autenticación

Objetivo. Que cada acción del sistema pueda atribuirse a una persona con confianza suficiente para sostenerla ante un auditor. Sigue las guías de identidad digital de NIST (SP 800-63B) vistas en clase: importan la longitud y que la contraseña no se repita en otros servicios, no las reglas de símbolos.

Regla	Qué establece	Por qué
POL-AU-01	**Longitud.** Mínimo 12 caracteres; se aceptan hasta 64 o más, con espacios y cualquier carácter. Se recomiendan frases. No se exigen mayúsculas, números ni símbolos.	Las reglas de composición producen contraseñas predecibles; la longitud es lo que cuesta adivinar.
POL-AU-02	**Sin vencimiento periódico.** La contraseña se cambia solo cuando hay indicio de que se comprometió.	El cambio forzado lleva a variaciones mínimas de la misma contraseña.
POL-AU-03	**Lista de bloqueo.** Se rechaza toda contraseña que aparezca en filtraciones conocidas o que contenga el nombre de la persona, de la empresa o de una finca.	El atacante no rompe el cifrado: prueba contraseñas ya filtradas en otros sitios.
POL-AU-04	**Personal e intransferible.** No se comparte con nadie, tampoco con la jefatura ni con soporte. Se permite y se recomienda un gestor de contraseñas.	Una cuenta prestada rompe la separación entre quien mide y quien aprueba, y deja la bitácora sin valor.

Regla	Qué establece	Por qué
POL-AU-05	**Segundo factor obligatorio para todos los roles.** Preferido: llave de acceso del propio dispositivo (*passkey*, FIDO2). Respaldo, para equipos que no la admiten: aplicación de códigos temporales. No se aceptan códigos por SMS ni por correo. Gerencia, administrador, operador y auditores usan siempre llave de acceso. No se compran llaves físicas para todo el personal (ver la comparación abajo). [minuta P-23]	El SMS se roba duplicando el chip; el código temporal se puede pedir en una página falsa; la llave de acceso está ligada al sitio real y además es lo más rápido para un técnico en el campo.
POL-AU-06	**Reautenticación en las decisiones.** Aprobar o devolver una medición, autorizar o verificar una enmienda, cerrar un período, aprobar altas o roles y resolver una alerta exigen el segundo factor en los cinco minutos previos.	Liga la decisión a la persona presente, no a una sesión que quedó abierta.
POL-AU-07	**Intentos fallidos.** Demora creciente desde el quinto intento; bloqueo de 15 minutos al décimo, con aviso al titular y al administrador.	Frena la adivinación sin permitir que un tercero deje a alguien sin cuenta de forma permanente.
POL-AU-08	**Sesiones.** Se cierran tras 30 minutos sin actividad y, como máximo, a las 12 horas. Se cierran todas al cambiar la contraseña, el rol o al dar de baja la cuenta. Solo por conexión cifrada.	Una sesión abierta en un equipo desatendido equivale a una contraseña prestada.
POL-AU-09	**Almacenamiento.** El sistema nunca guarda contraseñas legibles ni cifradas de forma reversible: guarda un resumen calculado con Argon2id y una sal distinta por usuario.	Si la base se filtra, las contraseñas no salen con ella.
POL-AU-10	**Recuperación con dos personas.** Restablecer una contraseña o un segundo factor requiere que el administrador verifique la identidad y que la Gerencia lo apruebe. Nunca se hace solo por teléfono.	El mostrador de soporte es el objetivo preferido de la ingeniería social.
POL-AU-11	**Equipos.** Todo dispositivo se trata como no confiable: ningún permiso depende del equipo ni de la red. El servidor exige navegador vigente, conexión cifrada y segundo factor, y la aplicación no guarda datos en el equipo. Un ingreso desde un equipo nuevo se avisa al titular de la cuenta y a su supervisor. Bloqueo de pantalla y cifrado: obligatorios en los equipos de la empresa, condición de uso en los personales. La pérdida se reporta de inmediato y cierra las sesiones. [minuta P-22]	La empresa no puede garantizar equipos de campo iguales ni conectados a su red. El teléfono de un técnico es el más expuesto.
POL-AU-12	**La dirección de red no identifica a nadie.** El origen de la conexión se usa como señal de alerta, nunca como prueba de identidad.	Muchas personas comparten una misma dirección, y se puede falsificar.

¿Hacen falta llaves físicas de seguridad? El cliente no comprometió presupuesto para darlas a todo el personal y pidió justificar su uso, su costo y las alternativas. [minuta P-23]

Opción	Qué protege	Costo	Decisión
Llave física FIDO2 para todo el personal	Resiste el correo falso y no depende del equipo de la persona.	Dos por persona, para no quedar fuera si una se pierde, más reposición y entrega en el campo.	No.
Llave de acceso del propio dispositivo	La misma resistencia al correo falso: la credencial solo funciona en el sitio real.	Ninguno. Pide un teléfono o computador razonablemente reciente.	Sí, para todos.
Aplicación de códigos temporales	Menos: el código se puede pedir en una página falsa.	Ninguno.	Solo como respaldo.
Llave física solo para las cuentas de mayor privilegio	Lo mismo que la primera, donde una cuenta robada haría más daño: Gerencia, administrador, operador y custodios de la bóveda.	Unas pocas llaves, una sola vez; entre 25 y 60 dólares cada una, como referencia.	Recomendada.

Si Verdeazul decide no comprar ninguna, esas cuentas usan la llave de acceso de su equipo y el riesgo queda declarado (Entregable 4, RR-7). Los precios deben cotizarse.

8 Política de períodos, correcciones y certificados

Objetivo. Que el dato que respalda un certificado cambie por un solo camino, y que cualquiera pueda comprobar si un certificado es auténtico y sigue vigente. **Responsable.** La Gerencia de Certificación.

Regla	Qué establece	Cómo se comprueba
POL-CE-01	**Apertura y cierre entre dos.** La coordinación de certificación decide las fechas; el personal administrativo las registra y la Gerencia las aprueba en el sistema. El cierre detiene el registro y la modificación de mediciones; no detiene la revisión de lo que se envió a tiempo. Un período cerrado no se reabre. [minuta P-05, P-06]	Aperturas o cierres hechos por una sola persona: cero.
POL-CE-02	**Corrección formal.** Después de la aprobación o del cierre, un dato solo cambia por enmienda. La solicita el técnico responsable, un verificador o la Gerencia; la corrige el técnico; la revisa un verificador independiente; la autoriza la Gerencia. Son personas distintas. El verificador nunca edita la medición de otro. [minuta P-03, P-07]	Enmiendas en que una persona dio dos pasos: cero.
POL-CE-03	**Certificado afectado.** Si una enmienda cambia las toneladas certificadas, el certificado se revoca y se emite otro, enlazado al anterior, en un solo acto. Ningún certificado se borra y nunca hay dos vigentes para la misma parcela y período. Si ya fue comercializado, la Gerencia avisa al dueño, coordina con las partes y lo deja registrado. [minuta P-08]	Parcelas y períodos con más de un certificado vigente: cero.
POL-CE-04	**Autenticidad y estado.** Cada certificado lleva el sello electrónico de la empresa, el nombre de quien aprobó la medición y un código. Con ese código cualquiera comprueba en línea si es auténtico y si sigue vigente. [minuta P-04]	Un certificado revocado se muestra como revocado, con el código de su reemplazo.

9 Cumplimiento

Quién responde por qué.

Quién	Responsabilidad
Gerencia General	Aprueba esta política y sus excepciones mayores. Recibe las alertas que involucran a la Gerencia de Certificación.
Gerencia de Certificación	Dueña de la política y de los datos. Aprueba roles y períodos, autoriza enmiendas, revisa accesos y atiende alertas.
Supervisor de campo	Asigna las fincas y atiende las alertas de sus técnicos.
Administrador de catálogo y cuentas	Ejecuta altas, cambios y bajas, y registra los períodos. Atiende las solicitudes de los dueños sobre sus datos.
Operador de plataforma	Personal designado por la empresa. Custodia servidores, respaldos y llaves. No decide sobre los datos.
Todo el personal, los auditores y los dueños	Cumplen la política y reportan cualquier incidente o sospecha el mismo día.

Sanciones. Sin consecuencia, una política es una sugerencia. Para el personal, el incumplimiento es una falta que se sanciona según el reglamento interno y el Código de Trabajo, y puede llegar al despido. Para auditores y proveedores, es causa de terminación del contrato. Cuando el hecho pueda ser un delito de los citados en la sección 5, la empresa presenta la denuncia y aporta la bitácora como evidencia.

Excepciones. Solo por escrito, aprobadas por la Gerencia de Certificación, con fecha de vencimiento y registradas. No se conceden excepciones a las reglas POL-CA-10, POL-CA-14, POL-BT-03 y POL-BT-06.

Capacitación y revisión. Todo el personal recibe, al ingresar y una vez al año, una sesión sobre esta política, sobre cómo reconocer un correo falso y sobre cómo reportar un incidente. La política se revisa una vez al año, después de cada incidente y cuando cambie una norma de la sección 5.

Indicadores. La Gerencia los revisa al cierre de cada período.

Indicador	Meta
Mediciones aprobadas por alguien que participó en ellas	0
Certificados vigentes repetidos para una misma parcela y período	0
Cambios sobre mediciones aprobadas o períodos cerrados hechos fuera de una enmienda	0
Bajas con la cuenta desactivada el mismo día	100 %
Cuentas con dos roles sin habilitación vigente, o sin revisión en el período	0
Decisiones tomadas por una persona con vínculo declarado con la finca	0
Alertas de historial sin atender en cinco días hábiles	0
Personal con la capacitación anual al día	100 %
Pruebas de restauración de respaldos en el año	2

Anexo A. Minuta de la consulta al cliente

El enunciado establece que las dudas sobre el encargo se resuelven en una consulta formal con la parte interesada, que lo respondido queda en minuta, que la minuta la redacta el equipo y que se adjunta a este informe. El cliente respondió por escrito. Esta minuta transcribe sus respuestas de forma literal y anota, debajo de cada una, qué decidió el equipo y en qué documento quedó. E1 es este informe, E2 el documento de control de acceso, E3 la matriz y E4 la arquitectura.

Datos de la consulta

Solicitud	Correo a `a.vargas@itcr.ac.cr`, asunto «CE1115 - Grupo 6 - Consultas VERDEAZUL CARBONO S.A», enviado el [por completar].
Respuesta	Por escrito, recibida el [por completar].
Por el cliente	Prof. MSc. Andrés Vargas Rivera, en el papel de Verdeazul Carbono S.A.
Por el equipo	Randall Bolaños López, Javier Tenorio Cervantes, Julio Varela Venegas y Axel Flores Lara.
Alcance	El equipo preparó 26 consultas escritas, numeradas de P-01 a P-26. El cliente respondió catorce.
Redactó la minuta	El equipo (Grupo 6).

Numeración. La respuesta del cliente numera sus catorce puntos de corrido, de P-01 a P-14. Los ocho primeros coinciden con la numeración del equipo. Los seis restantes corresponden a las consultas P-10, P-11, P-15, P-18, P-22 y P-23 del equipo. La minuta y los cinco entregables usan siempre la numeración del equipo; entre paréntesis se indica el número que lleva en la respuesta del cliente cuando es distinto.

Resumen: qué pasó con cada supuesto

N.°	Supuesto con que se había diseñado	Resultado	Lo que queda establecido
P-01	Un verificador nunca mide.	**Cambia**	Puede medir por excepción, con una habilitación temporal. No aprueba lo que midió.
P-02	Hay al menos dos verificadores.	Se ajusta	Sin cifras: el diseño no depende de cantidades fijas.
P-03	El verificador devuelve; nunca edita.	Se confirma	Devuelve con observaciones. Tras la aprobación, solo por enmienda.
P-04	Sello de la empresa, sin firma personal.	Decide el equipo	Sello de la empresa, comprobación en línea del estado y aprobación personal registrada.
P-05	La Gerencia abre, cierra y asigna.	**Cambia**	Decide la coordinación, registra el administrador y aprueba la Gerencia. Asigna un rol nuevo: el supervisor de campo.
P-06	Lo no aprobado al cierre queda fuera.	**Cambia**	El cierre detiene registrar y modificar; revisar y aprobar siguen.
P-07	Autoriza la Gerencia; verifica después otro verificador.	**Cambia**	Solicitar, corregir, revisar y autorizar, con personas independientes. Verificador distinto si la enmienda es material.

N.°	Supuesto con que se había diseñado	Resultado	Lo que queda establecido
P-08	Se revoca y se reemite.	Se ajusta	Si cambian las toneladas, revocar y reemitir en un solo acto. Nunca dos vigentes; ninguno se borra.
P-10	Avisar, confirmar y bloquear.	Se ajusta	Aviso, verificación adicional y restricción temporal, según la gravedad. No se bloquea de entrada.
P-11	El técnico solo ve sus fincas.	Se confirma, con ajuste	Asignaciones temporales para apoyos, sustituciones y visitas.
P-15	Los dueños entran y autorizan representantes.	Se amplía	Personas físicas y sociedades. Declaración de vínculos y abstención.
P-18	Solo lectura, sin copias; normas ISO.	**Cambia**	Ninguna norma se da por supuesta. Acceso remoto y exportación de evidencia, dentro de la ventana.
P-22	Registro en línea, con equipo de la empresa.	**Cambia**	Registro posterior a la visita, con dos fechas. Equipos no confiables. Sin aplicación sin conexión.
P-23	Un proveedor opera el servidor; sin llaves físicas.	Decide el equipo	Servidor virtual contratado, operado por personal designado. Llaves físicas solo para cuentas privilegiadas.

Aclaración inicial del cliente

> Muchas gracias por las consultas. Nos parece importante que comprendan nuestros procesos antes de finalizar su propuesta, especialmente porque buscamos una plataforma que sea segura, práctica y que pueda adaptarse al crecimiento de la empresa.

A. Quién mide y quién aprueba

P-01 ¿Un verificador puede realizar mediciones? ¿Existen verificadores que anteriormente fueron técnicos?

> Sí. Algunos verificadores tienen experiencia previa como técnicos de campo y, en situaciones excepcionales, podrían colaborar realizando mediciones.
>
> Sin embargo, nos preocupa que una persona pueda registrar y aprobar su propio trabajo. Necesitamos garantizar una revisión independiente, sin impedir que el personal pueda asumir otras responsabilidades cuando sea necesario.

Decisión del equipo. La exclusión entre técnico y verificador deja de ser estática. Un verificador puede medir con una habilitación temporal de técnico, con fecha de fin, que propone el administrador y aprueba la Gerencia. Lo que mida no lo podrá aprobar nunca, porque la separación se comprueba medición por medición. Queda en: POL-CA-03; E2 §3.4 y §5.2; E3, restricciones entre roles, regla C3 y caso T-26.

P-02 ¿Cuántos técnicos, verificadores y fincas tenemos actualmente?

> No tenemos cifras definitivas para dimensionar la nueva plataforma. Además, esperamos incorporar nuevos empleados y fincas durante los próximos años.
>
> Por esta razón, preferimos que el diseño no dependa de cantidades fijas de usuarios, fincas o asignaciones.
>
> Pueden establecer supuestos razonables de capacidad para justificar sus decisiones técnicas, siempre que queden claramente documentados.

Decisión del equipo. El diseño no usa cantidades fijas. Los roles son siete con cualquier número de fincas; los umbrales de los controles de historial son parámetros por rol que se calibran con datos reales; y el único mínimo es de independencia: dos verificadores activos. Los supuestos de capacidad con que se dimensionó el servidor están declarados. Queda en: E2 §3.5 y §4; E3 §4; E4 §1 y Anexo B.

P-03 Cuando una medición presenta errores, ¿el verificador la corrige directamente?

> Normalmente el verificador devuelve la medición al técnico responsable, indicando las observaciones correspondientes.
>
> No queremos que los verificadores modifiquen silenciosamente las mediciones de otras personas.
>
> Si se detecta un error después de aprobada una medición, debe existir un procedimiento formal que permita conservar el historial de los cambios.

Decisión del equipo. Se confirma el supuesto. El verificador no tiene permiso de crear ni de modificar mediciones; devuelve con una observación obligatoria. Después de aprobada, el dato solo cambia por enmienda, y en ella corrige el técnico, nunca el verificador. Queda en: POL-CE-02; E3, celda (VER, Mediciones) y regla C9.

P-04 ¿Cómo se emite un certificado? ¿Utilizamos firma digital certificada?

> Actualmente, el certificado se genera una vez que la medición ha sido revisada y aprobada por el personal correspondiente.
>
> La gerencia interviene cuando existen situaciones extraordinarias que requieren una autorización especial.
>
> Actualmente no tenemos un mecanismo de firma digital certificada definido para la nueva plataforma. Nos interesa que puedan demostrarse la autenticidad del certificado, su estado y quién autorizó su emisión.
>
> Esperamos que ustedes valoren si una firma digital es necesaria y qué alternativas existen.

Decisión del equipo. El equipo valoró la firma digital certificada de la Ley 8454 y concluye que no hace falta exigirla a cada verificador. Las tres cosas que el cliente quiere demostrar se cubren así: la autenticidad, con el sello electrónico de la empresa; el estado, con una comprobación en línea por el código del certificado, porque una firma no dice si el documento fue revocado después; y quién autorizó, con la aprobación personal con segundo factor, que queda en la bitácora y se imprime en el certificado. Queda en: POL-CE-04; E3, fila PUB y regla C20; E4 §4.8, con las alternativas y su costo.

B. Períodos y enmiendas

P-05 ¿Quién abre y cierra los períodos? ¿Quién asigna los técnicos?

> La coordinación de certificación determina cuándo comienza y termina un período de medición.
>
> El personal administrativo puede encargarse de registrar estas operaciones en el sistema, siguiendo las indicaciones correspondientes.
>
> Las asignaciones de fincas normalmente son coordinadas por los supervisores del personal de campo. Debe existir la posibilidad de realizar reasignaciones por vacaciones, incapacidades o necesidades operativas.

Decisión del equipo. Dos cambios. Primero, las fechas de un período las decide la coordinación de certificación, que el diseño reúne con la Gerencia en el rol GER; el personal administrativo las registra, y el período no se abre ni se cierra hasta que GER lo aprueba en el sistema, de modo que la indicación queda escrita. Segundo, aparece una función de trabajo nueva, el supervisor de campo, y con ella el séptimo rol: asigna y reasigna fincas, con asignaciones temporales para vacaciones, incapacidades y necesidades operativas. La Gerencia deja de asignar. Queda en: POL-CA-13 y POL-CE-01; E2 §3; E3, fila SUP, columnas Períodos y Asignaciones, reglas C14 y C19.

P-06 ¿Las verificaciones terminan antes del cierre del período?

> No necesariamente. Pueden existir mediciones pendientes de revisión cuando finaliza un período.
>
> El cierre debe impedir que se sigan registrando o modificando libremente las mediciones correspondientes a ese período.
>
> Sin embargo, necesitamos poder finalizar la revisión de aquellas mediciones que fueron registradas oportunamente.
>
> Cuando una medición requiera cambios después del cierre, estos deben tramitarse mediante el procedimiento formal de correcciones.
>
> Esperamos que su diseño permita distinguir entre registrar, modificar, revisar y aprobar información.

Decisión del equipo. Cambia el supuesto: lo que no estaba aprobado al cierre ya no queda fuera. El cierre quita los permisos de registrar y de modificar; los de revisar y aprobar siguen para toda medición enviada antes del cierre. Lo que se devuelva después del cierre, y los borradores que nunca se enviaron, solo cambian por enmienda. Queda en: POL-CE-01; E3, reglas C3 y C14, casos T-17, T-21 y T-22; E4, Anexo A.3.

P-07 ¿Quién solicita y autoriza una corrección posterior al cierre?

> Una corrección puede ser solicitada por el técnico responsable, un verificador o el personal de certificación cuando se identifica un error.
>
> La autorización final corresponde a la gerencia de certificación y debe contar con una revisión técnica que respalde el cambio.
>
> Nos interesa mantener independencia entre quienes solicitan, revisan y autorizan modificaciones importantes.
>
> No hemos establecido que necesariamente deba participar un verificador distinto al original en absolutamente todos los casos. Esperamos que ustedes evalúen esa posibilidad y justifiquen qué restricciones consideran necesarias.

Decisión del equipo. La enmienda cambia de orden para que la autorización de la Gerencia sea el último paso y se apoye en la revisión: solicitar, corregir, revisar, autorizar. Solicita el técnico responsable, un verificador o la Gerencia; corrige el técnico; revisa un verificador; autoriza la Gerencia. Nadie da

dos pasos. Sobre lo que quedó a criterio del equipo: se exige un verificador distinto del original cuando la enmienda es material, es decir, cuando cambia un dato del cálculo de toneladas o la medición ya tiene un certificado. En las demás puede revisar el original. La clasificación la hace el sistema, no una persona. Queda en: POL-CE-02; E2 §5.3, con la justificación; E3, reglas C7 a C10, casos T-12, T-23 y T-24.

P-08 ¿Qué sucede cuando una corrección afecta un certificado emitido o vendido?

> Esta es una de nuestras principales preocupaciones.
>
> Si una corrección modifica las toneladas de carbono certificadas, necesitamos evaluar si el certificado continúa siendo válido.
>
> En casos importantes podría ser necesario revocarlo y emitir uno nuevo, conservando la relación y el historial de ambos documentos.
>
> Si el certificado ya fue comercializado, la gerencia deberá coordinar las acciones correspondientes con las partes involucradas.
>
> En ningún caso queremos que un certificado desaparezca del historial ni que existan dos certificados vigentes respaldando la misma captura de carbono.

Decisión del equipo. La evaluación se convierte en una regla. La revisión técnica calcula el efecto de la corrección. Si las toneladas certificadas no cambian, el certificado sigue vigente con la enmienda anotada. Si cambian, al autorizar el sistema revoca el certificado y emite el reemplazo en un solo acto, enlazados entre sí: nunca hay dos vigentes y ninguno se borra. Si ya fue comercializado, la Gerencia lo deja registrado en la autorización, el dueño recibe aviso y la coordinación con terceros queda documentada; el estado nuevo lo puede ver cualquiera en la comprobación pública. Queda en: POL-CE-03; E3, reglas C4 y C8, caso T-25.

C. El comportamiento sospechoso del técnico

P-10 (n.° 9 en la respuesta) **¿Qué esperamos que haga el sistema ante consultas masivas de información?**

> Como mínimo, queremos que el sistema detecte comportamientos inusuales y genere alertas para el supervisor correspondiente o la gerencia de certificación.
>
> No necesariamente deseamos bloquear de inmediato al usuario. Algunas actividades extraordinarias pueden ser legítimas.
>
> Consideramos razonable que las respuestas sean diferentes según la gravedad del comportamiento, desde una alerta hasta una verificación adicional o una restricción temporal.
>
> Esperamos que ustedes propongan y justifiquen los criterios para distinguir una actividad legítima de una potencial amenaza, considerando también los falsos positivos.

Decisión del equipo. El diseño original bloqueaba pronto: suspendía la sesión a la quinta denegación. Se rehízo en tres niveles: aviso, verificación adicional con segundo factor y motivo, y restricción temporal de fincas nuevas, que no cierra la cuenta ni interrumpe el trabajo en curso. El nivel sube según cuántas señales coinciden: volumen, novedad, momento e insistencia. Los avisos van al supervisor del técnico o a la Gerencia. Queda en: POL-CA-12; E2 §4.1 y §4.2, con los criterios y los falsos positivos; E3, controles H1 y H3, regla C15, casos T-19 y T-33.

P-11 (n.º 10 en la respuesta) **¿Un técnico necesita consultar fincas que no tiene asignadas?**

> Normalmente, los técnicos trabajan con un conjunto de fincas asignadas.
>
> Sin embargo, existen situaciones donde deben apoyar a compañeros, sustituir personal ausente o atender visitas extraordinarias.
>
> Por lo tanto, necesitamos cierta flexibilidad operativa, pero no consideramos necesario que todos los técnicos tengan acceso permanente a la información de todas las fincas.

Decisión del equipo. Se confirma el supuesto, con un ajuste. El técnico solo ve las fincas que tiene asignadas; nadie tiene acceso permanente a todas. La flexibilidad se da con asignaciones temporales que crea el supervisor, con motivo y fecha de fin, y que vencen solas. Queda en: POL-CA-13; E3, reglas C1 y C19, caso T-27.

D. Dueños de fincas y auditores

P-15 (n.º 11 en la respuesta) **¿Los dueños ingresarán al sistema? ¿Pueden tener varias fincas o delegar el acceso? ¿Existen conflictos de interés?**

> Sí, esperamos que los propietarios puedan ingresar al sistema para consultar sus mediciones y certificados.
>
> Trabajamos tanto con personas físicas como con sociedades. Un mismo propietario puede tener varias fincas y una sociedad puede necesitar que un representante autorizado consulte su información.
>
> Las cuentas iniciales serán habilitadas por personal administrativo, después de verificar la relación del solicitante con las propiedades correspondientes.
>
> Respecto a posibles vínculos familiares o comerciales entre empleados y propietarios, no contamos con un registro formal que permita descartar todos esos casos.
>
> Nos interesa que su diseño contemple cómo evitar que una persona utilice sus responsabilidades dentro de la empresa para beneficiar indebidamente una propiedad con la que tenga alguna relación.

Decisión del equipo. Tres decisiones. La cuenta de dueño siempre es de una persona: el titular o, cuando el titular es una sociedad o así lo dispone, un representante autorizado; un titular puede tener varias fincas. La habilita el administrador después de verificar la relación con cada finca, y el alta de un representante se notifica al titular. Y como no existe un registro de vínculos, el diseño lo crea: todo el personal declara sus vínculos familiares o comerciales con dueños al ingresar y antes de cada período, y quien declara uno queda apartado de toda decisión sobre esa finca. Lo que nadie declara es un riesgo residual, acotado por la separación entre personas, los indicadores y la sanción. Queda en: POL-CA-08, POL-CA-14 y amenaza AM-11; E3, reglas C5, C13 y C17, caso T-29; E4, RR-11.

P-18 (n.º 12 en la respuesta) **¿Quiénes auditan, bajo qué norma y cómo realizan las auditorías?**

> Recibimos auditorías externas, principalmente relacionadas con nuestros compromisos en mercados internacionales de carbono.
>
> La carta de encargo no establece una norma específica de certificación o auditoría, por lo que no deben asumir que utilizamos un estándar determinado.
>
> Sí tenemos un requerimiento claro: poder reconstruir la trazabilidad de los certificados emitidos durante los últimos diez años.
>
> Las auditorías se realizan normalmente una vez al año y pueden extenderse durante varios días. Los auditores pueden trabajar presencialmente o requerir acceso remoto a la documentación.

> Necesitan consultar registros y, en algunas ocasiones, exportar evidencia para sus informes. No deben modificar los datos.
>
> El acceso debe limitarse al período autorizado de auditoría, salvo una nueva autorización.

Decisión del equipo. No se asume ninguna norma: las ISO que el informe citaba como «normas que aplicarán los auditores» quedan como referencia de buenas prácticas. El requisito firme es reconstruir la trazabilidad de los certificados de los últimos diez años. La cuenta de auditor es personal, de solo lectura, sirve en sitio o a distancia y vence con la ventana autorizada; prorrogarla es una autorización nueva. Se agrega el permiso de exportar evidencia, como paquetes que genera el sistema, sellados, registrados y sin datos personales. Queda en: Sección 5, POL-CA-07 y POL-BT-04; E3, fila AUD, reglas C6 y C18, caso T-31.

E. Administración y operación

P-22 (n.º 13 en la respuesta) **¿Cómo registran las mediciones? ¿Existe conectividad? ¿Qué equipos utilizan?**

> Las mediciones se realizan directamente en las fincas, pero la conectividad a internet no siempre es estable, especialmente en zonas rurales.
>
> Por esa razón, algunos técnicos recopilan la información durante la visita y posteriormente la registran en los sistemas administrativos.
>
> No podemos garantizar que todos los dispositivos utilizados en campo tengan las mismas características o estén permanentemente conectados a la red de la empresa.
>
> Nos interesa que el diseño contemple estas condiciones, especialmente la trazabilidad de las fechas de medición y registro, así como los riesgos de acceso desde dispositivos utilizados fuera de nuestras oficinas.
>
> Para esta etapa no estamos solicitando desarrollar una aplicación sin conexión, pero sí considerar las implicaciones de nuestra forma de trabajo.

Decisión del equipo. No se diseña una aplicación sin conexión. Sí cambian tres cosas. Cada medición guarda dos fechas: la de medición, que declara el técnico, y la de registro, que pone el servidor; la primera debe caer dentro del período y de la asignación, y la diferencia entre ambas queda a la vista del verificador. El período tiene una fecha de fin de medición y otra, posterior, de cierre de registro, para que lo medido el último día se pueda registrar. Y ningún permiso depende del equipo ni de la red: todo dispositivo se trata como no confiable, la aplicación no guarda datos en él y la hoja de campo se registra dentro de un plazo. Queda en: POL-AU-11, POL-BT-02 y POL-TR-03; E3, regla C2 y caso T-30; E4 §4.7 y RR-8.

P-23 (n.º 14 en la respuesta) **¿Dónde se hospedará el sistema? ¿Quién lo operará? ¿Hay presupuesto para servidores y llaves físicas de seguridad?**

> Todavía no hemos decidido si la plataforma será hospedada en infraestructura propia o mediante un proveedor externo.
>
> Esperamos recibir una recomendación fundamentada, considerando seguridad, mantenimiento, disponibilidad y costos.
>
> Contamos con la restricción de utilizar software libre, pero entendemos que la infraestructura necesaria para ejecutar el sistema tendrá costos.
>
> No hemos comprometido presupuesto para entregar llaves físicas de seguridad a todos los empleados. Si consideran que son necesarias, deberán justificar su uso, costos y alternativas.

> La operación técnica cotidiana estará a cargo del personal que la empresa designe, aunque actualmente no contamos con un equipo especializado de ciberseguridad.
>
> Por ello, preferimos una solución que pueda mantenerse sin depender de una infraestructura excesivamente compleja o de personal altamente especializado para cada tarea cotidiana.

Decisión del equipo. El equipo recomienda un servidor virtual contratado a un proveedor externo, operado por el personal que Verdeazul designe con guías escritas, y soporte especializado por contrato solo para lo extraordinario. Sobre las llaves físicas: no son necesarias para todo el personal, porque la llave de acceso del propio dispositivo da la misma resistencia al correo falso sin costo; se recomiendan solo para las pocas cuentas de mayor privilegio. Queda en: POL-AU-05, con la comparación de opciones, y POL-CA-09; E4 §1, §5 y Anexo B, RR-7 y RR-12.

Consideraciones finales del cliente

> Queremos enfatizar que estas respuestas describen nuestras necesidades y condiciones operativas, pero no representan una especificación técnica de la solución.
>
> Esperamos que, como equipo consultor, ustedes determinen y justifiquen:
>
> - El modelo de control de acceso y las condiciones bajo las cuales se autorizan las operaciones.
> - Los mecanismos para prevenir modificaciones o aprobaciones indebidas.
> - Los controles para identificar actividades inusuales sin perjudicar innecesariamente el trabajo legítimo.
> - Las tecnologías y los mecanismos de seguridad apropiados para nuestras necesidades y restricciones presupuestarias.
>
> No buscamos necesariamente el sistema más complejo, sino uno donde cada decisión de seguridad tenga una justificación clara y responda a un riesgo real de nuestra operación.
>
> Pueden incorporar estas aclaraciones como anexo de su documentación y utilizarlas para completar su propuesta.

Decisión del equipo. El equipo toma esta última indicación como criterio de revisión: cada control que se agregó después de la consulta cita la respuesta o la amenaza que lo justifica, y lo que se pudo resolver con un atributo no se resolvió con un componente nuevo.

Consultas que el cliente no respondió

Doce consultas quedaron sin respuesta: P-09, P-12, P-13, P-14, P-16, P-17, P-19, P-20, P-21, P-24, P-25 y P-26. Ninguna era de las que cambian el diseño. El equipo las resolvió con supuestos razonables, como el cliente autorizó, y los documenta en el Anexo B.

Anexo B. Supuestos declarados

El cliente no respondió estas consultas. El equipo fijó un supuesto para cada una, dice por qué es razonable y qué habría que ajustar si el dato real resulta distinto. En los entregables se reconocen por la marca [supuesto P-00].

Consulta	Supuesto declarado	Por qué es razonable	Dónde se usa y qué se ajustaría
P-09	Las enmiendas son pocas por período.	Corrigen errores, no son la vía normal de trabajo.	E2 §5.6: la fricción aceptable de la enmienda.
P-12	La jornada es de lunes a viernes, de 6:00 a 19:00.	Es un parámetro por rol que aprueba la Gerencia; no restringe el registro de campo.	E2 §4.2: valores de H2 y H3.
P-13	Hasta calibrar: 40, 60 y 80 fincas distintas por día.	El primer período corre en observación y los umbrales se fijan con datos reales.	E2 §4.2: valores de H1.
P-14	El personal firma confidencialidad y uso aceptable, y sabe que sus consultas se registran.	Lo exige esta política desde la puesta en marcha; no depende de la práctica actual.	POL-CA-02; E2 §4.3.
P-16	El dueño ve una medición solo cuando está aprobada.	Antes de aprobarse el dato puede cambiar; mostrarlo expone al verificador a presiones.	E3, regla C5.
P-17	Se guardan identificación y contacto del titular y de sus representantes.	Es lo mínimo para verificar la relación con la finca.	Activo A-04; Ley 8968.
P-19	Cambios y decisiones, diez años. Consultas y autenticación, dos.	El cliente pide la trazabilidad de los certificados; las consultas no forman parte de ella, y la Ley 8968 pide no conservar de más.	POL-BT-04; E4 §4.5.
P-20	La jefatura solicita la cuenta, el administrador la crea y la Gerencia aprueba el rol.	Reparte entre tres personas lo que hoy hace una.	POL-CA-02; E3, regla C12.
P-21	Una hectárea se identifica por la geometría de su parcela.	Es lo único que permite detectar dos parcelas que se traslapan.	E3, regla C11; E4 §3.
P-24	Se tolera un día sin sistema; no se tolera perder datos.	La operación es por períodos; lo irrecuperable es el histórico.	Sección 3; E4, RR-6. Si no se tolera, hace falta un segundo servidor.
P-25	Un tercero debe poder comprobar un certificado.	El cliente no la respondió de forma directa, pero su respuesta a P-04 lo pide: demostrar autenticidad y estado.	POL-CE-04; E3, regla C20.
P-26	El histórico se migra una sola vez y queda marcado.	El sistema nuevo no puede darle la trazabilidad que nunca tuvo; sí conservar la mejor evidencia.	POL-TR-01 a POL-TR-03; E4, RR-9.

Referencias

Asamblea Legislativa de la República de Costa Rica. (1943). *Código de Trabajo* (Ley N.º 2). Sistema Costarricense de Información Jurídica.

Asamblea Legislativa de la República de Costa Rica. (2000). *Ley de Información No Divulgada* (Ley N.º 7975). Sistema Costarricense de Información Jurídica.

Asamblea Legislativa de la República de Costa Rica. (2005). *Ley de Certificados, Firmas Digitales y Documentos Electrónicos* (Ley N.º 8454). *La Gaceta* N.º 197.

Asamblea Legislativa de la República de Costa Rica. (2011). *Ley de Protección de la Persona frente al Tratamiento de sus Datos Personales* (Ley N.º 8968). *La Gaceta* N.º 170.

Asamblea Legislativa de la República de Costa Rica. (2012). *Reforma de la sección VIII, Delitos informáticos y conexos, del título VII del Código Penal* (Ley N.º 9048). Sistema Costarricense de Información Jurídica.

International Organization for Standardization. (2019a). *Conformity assessment: General principles and requirements for validation and verification bodies* (ISO/IEC 17029:2019).

International Organization for Standardization. (2019b). *Greenhouse gases, part 3: Specification with guidance for the verification and validation of greenhouse gas statements* (ISO 14064-3:2019).

International Organization for Standardization. (2020). *General principles and requirements for bodies validating and verifying environmental information* (ISO 14065:2020).

International Organization for Standardization. (2022). *Information security, cybersecurity and privacy protection: Information security management systems, requirements* (ISO/IEC 27001:2022).

National Institute of Standards and Technology. (2004). *Standards for security categorization of federal information and information systems* (FIPS PUB 199). https://doi.org/10.6028/NIST.FIPS.199

Pfleeger, C. P., Pfleeger, S. L., & Margulies, J. (2015). *Security in computing* (5.ª ed.). Prentice Hall.

Poder Ejecutivo de la República de Costa Rica. (2012). *Reglamento a la Ley de Protección de la Persona frente al Tratamiento de sus Datos Personales* (Decreto Ejecutivo N.º 37554-JP). Sistema Costarricense de Información Jurídica.

Saltzer, J. H., & Schroeder, M. D. (1975). The protection of information in computer systems. *Proceedings of the IEEE, 63*(9), 1278–1308. https://doi.org/10.1109/PROC.1975.9939

Temoshok, D., Fenton, J. L., Choong, Y.-Y., Lefkovitz, N., Regenscheid, A., Galluzzo, R., & Richer, J. P. (2025). *Digital identity guidelines: Authentication and authenticator management* (NIST SP 800-63B-4). National Institute of Standards and Technology. https://doi.org/10.6028/NIST.SP.800-63B-4

Vargas Rivera, A. (2026a). *Material de estudio, clases 1, 3, 4 y 5: Componentes básicos, privacidad, principios y políticas de seguridad* [Material de clase]. Curso CE-1115 Seguridad de la Información, Instituto Tecnológico de Costa Rica.

Vargas Rivera, A. (2026b). *Material de estudio, clases 13 y 14: Autenticación y autorización* [Material de clase]. Curso CE-1115 Seguridad de la Información, Instituto Tecnológico de Costa Rica.

Vargas Rivera, A. (2026c). *Proyecto, parte 1: Diseño del control de acceso* [Enunciado de proyecto, incluye la carta de encargo de Verdeazul Carbono S.A.]. Curso CE-1115 Seguridad de la Información, Instituto Tecnológico de Costa Rica.